

Il ruolo del whistleblowing nella cyber security

Università degli Studi di Milano

Alessandro Rodolfi

Roma, 19 ottobre 2016



Era una notte buia e tempestosa...



Whistleblowing e Security, nemici o alleati?

Apetizer ITSecPro

*“Normativa italiano e sviluppo di politiche comunitarie sul Whistleblowing”
Alessandro Rodolfi*



Pacino Cafè, Milano

2 Febbraio 2012



Whistleblowing

- Il termine anglossassone whistleblowing identifica l'istituto giuridico e le attività di regolamentazione volte a disciplinare le procedure che incentivano e proteggono le persone che segnalano illeciti oppure irregolarità
- *“Whistleblowing is the popular term used when someone who works in or for an organization raises a concern about a possible fraud, crime, danger or other serious risk that could threaten customers, colleagues, shareholders, the public or the organization’s own reputation”*

Whistleblowing = leaking?

- Caratteristiche chiave del **whistleblowing**:
 - 1) scoperta di illeciti legati al posto di lavoro;
 - 2) interesse pubblico; 3) segnalazione degli illeciti attraverso canali e/o persone designate;
 - 4) buona fede; 5) esistenza di motivi ragionevoli
- Il **leaking** è una “falla in un sistema di comunicazione che fa fuoriuscire informazioni riservate che non dovrebbero circolare” (G. Ziccardi)

2012-2016

- **Fine 2012** L.190/2012 introduce l'art. 54-bis "*Tutela del dipendente pubblico che segnala illeciti*"
- **2013** P.N.A. + P.T.A.C. > tra gli obiettivi introdurre sistemi informatici di segnalazione
- **2013 Centralità della gestione del rischio**
- **2015** Linee guida ANAC in materia di whistleblowing
- **2015** 1° agg. Circolare 285/2013 BankIT > sistemi interni di segnalazione delle violazioni (whistleblowing)
- **2016** Proposta di legge in attesa di discussione al Senato con estensione al settore privato

Casi di frode rilevati nelle aziende private

Foul!

Fraud cases detected in private companies
by method, %*

External audit
5

Other
7

Document examination
8

Account reconciliation
8

Tip
36

Management review
15

By accident
11

Internal audit
12

* Adds up to more than 100% because of rounding

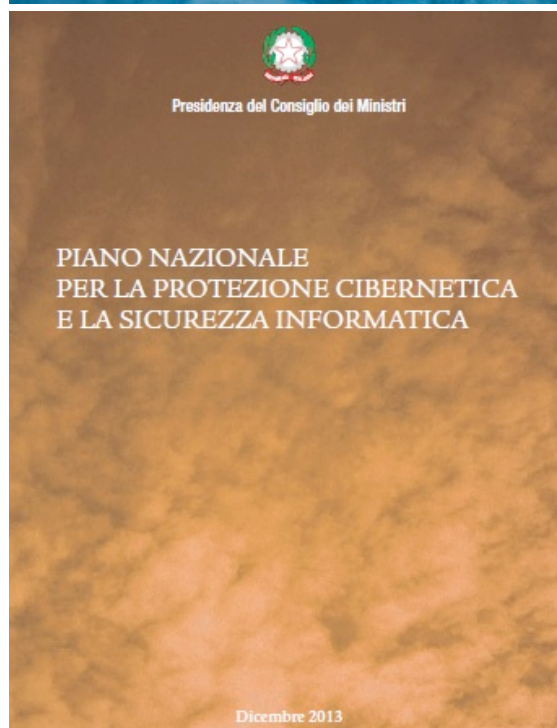
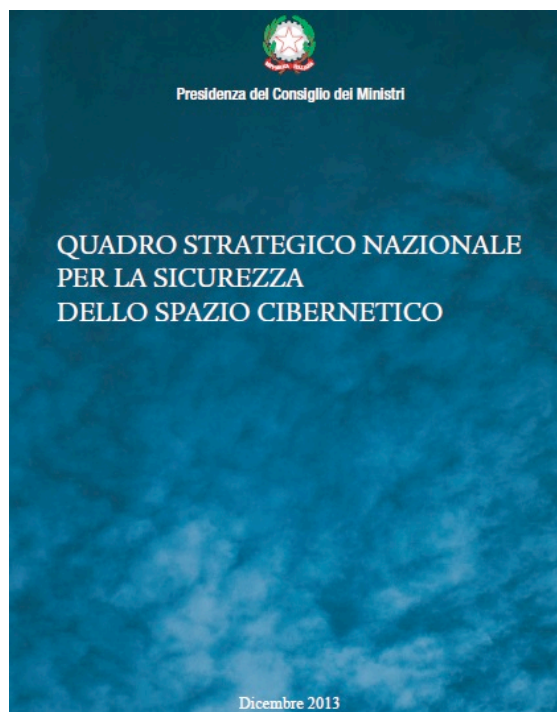
Sources: Association of Certified Fraud Examiners, 2010 Global Fraud Study; National Whistleblowers Centre

“Whistleblowing, the inside story”

- **83% segnala almeno due volte, di solito internamente**
- 15% segnala esternamente
- 74% dice che a seguito della segnalazione non si fa nulla
- 60% non riceve alcuna risposta (sia negativa che positiva)
- ...La risposta più probabile (19%) è un’azione formale (disciplinare o retrocessione) ai danni del whistleblower
- 15% è respinto
- I segnalatori anziani hanno maggiori probabilità di essere respinti
- I dipendenti assunti più recentemente hanno più probabilità di segnalare (il 39% è in servizio da meno di due anni)

<http://www.pcaw.org.uk/whistleblowing-the-inside-story>





PIANO NAZIONALE (PN)

INDIRIZZI OPERATIVI

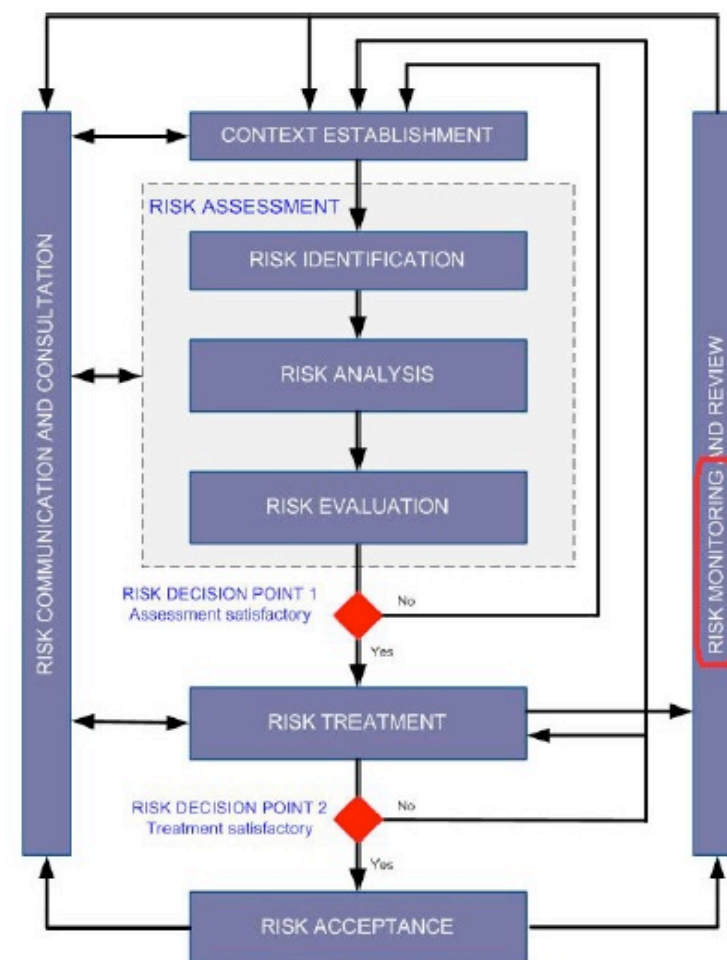
1. Potenziamento capacità di *intelligence*, di polizia e di difesa civile e militare
2. Potenziamento dell'organizzazione e delle modalità di coordinamento e di interazione a livello nazionale tra soggetti pubblici e privati
3. Promozione e diffusione della cultura della sicurezza informatica. Formazione e addestramento
4. Cooperazione internazionale ed esercitazioni
5. Operatività del CERT nazionale, del CERT-PA e dei CERT dicasteriali
6. Interventi legislativi e *compliance* con obblighi internazionali
7. *Compliance* a *standard* e protocolli di sicurezza
8. Supporto allo sviluppo industriale e tecnologico
9. Comunicazione strategica
10. Risorse
11. Implementazione di un sistema di *Information Risk Management* nazionale

1. Implementazione di un Information Risk Management nazionale

La protezione dei dati da minacce che ne pregiudicano l'autenticità, l'integrità, la riservatezza e la disponibilità è parte integrante del presente Piano Nazionale in quanto le informazioni costituiscono un valore intrinseco all'organizzazione, pubblica o privata, e imprescindibile obiettivo di ogni attacco cibernetico.

11.1 Metodologia

- Individuare una metodologia di *Information Risk Management* univoca e condivisa a livello strategico, adottando un modello per le infrastrutture critiche nazionali informatizzate, in accordo con la UNI EN ISO 27005:2011
- Coinvolgere centri di ricerca e università per consentire l'adozione di aggiornati strumenti di gestione del rischio

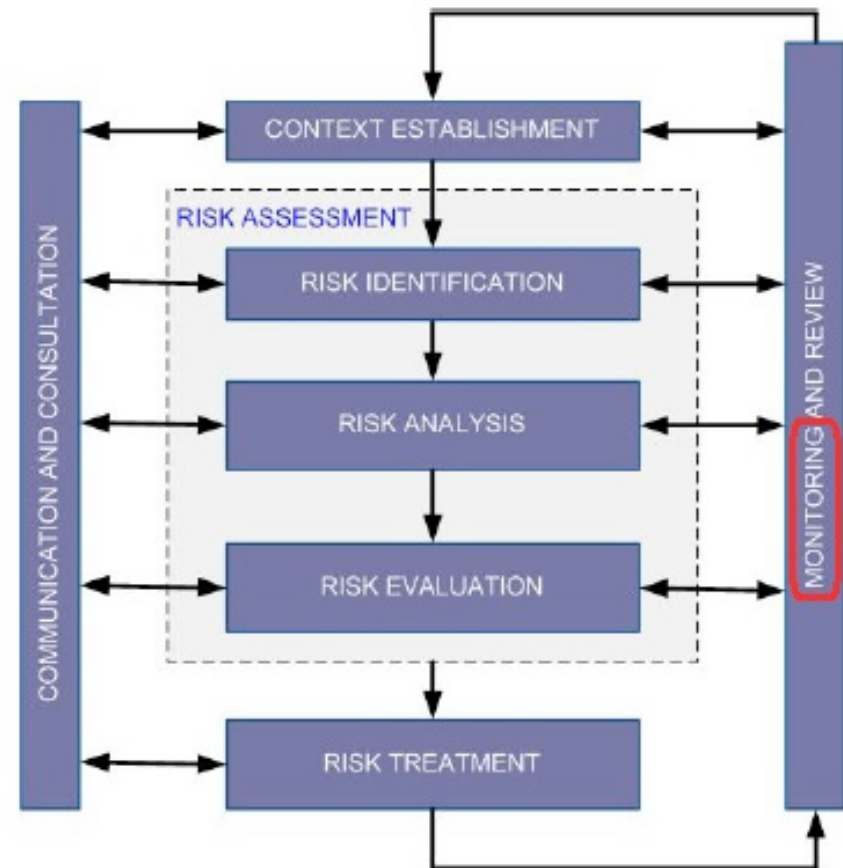
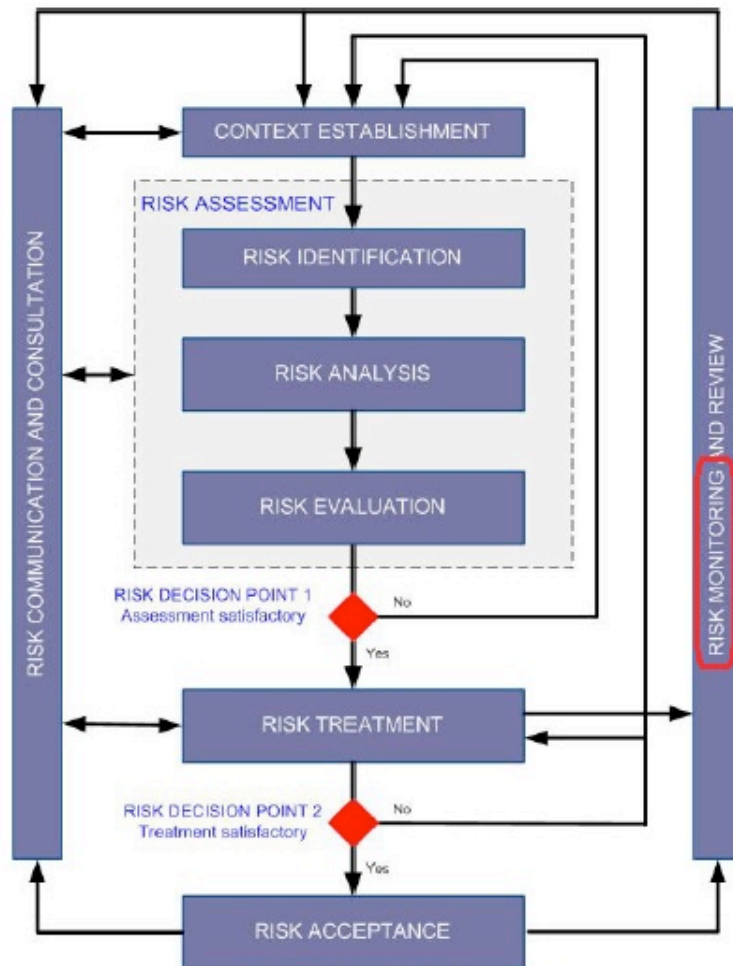


Information security risk monitoring

- Segnalazioni relative a nuove minacce interne/esterne
- Segnalazioni di nuove o più pericolose vulnerabilità
- Segnalazioni di incidenti di sicurezza
- Segnalazioni di data breaches
- Gli output delle attività di ISRM diventano dati di input per le attività di risk review



2013: 27005 > 31000



Principio j)

- La gestione del rischio è dinamica, iterativa e reattiva al cambiamento

ISO/TR 31004:2013

Risk management -- Guidance for the implementation of ISO 31000

Practical help

- When applying the risk management process and developing the statement of context, the components (e.g. features of the external environment) that are most likely to change should be identified, and they should be closely monitored for change. Any change could require reassessment of all or some of the documented risks.
- People should be encouraged to report concerns about the status quo (including whistle-blowers).
- Even small organizations should keep in mind global changes, e.g. the global financial crisis of 2008 had profound impacts on some small suppliers whose main customers were organizations impacted directly or indirectly by bank failures. Such external events or emerging circumstances may require proactive changes to the risk management framework.

2700 I

- **A.7.2** Sicurezza delle risorse umane durante l'impiego (Responsabilità della direzione)
- **A.16.1** Gestione degli incidenti relativi alla sicurezza delle informazioni e dei miglioramenti

g) are provided with an anonymous reporting channel to report violations of information security policies or procedures ("whistle blowing").

Management should demonstrate support of information security policies, procedures and controls, and act as a role model.

A.16.1.3	Segnalazione dei punti di debolezza relativi alla sicurezza delle informazioni	<i>Controllo</i> Deve essere richiesto a tutto il personale ed ai collaboratori che utilizzano i sistemi informativi ed i servizi dell'organizzazione di registrare e <u>segnalare ogni punto di debolezza</u> relativo alla sicurezza delle informazioni che sia stato osservato o sospettato nei sistemi o nei servizi.
----------	--	--

Best Practices E.R.M.

- Far sentire il personale a suo **agio**
- Adozione procedure per rendere affidabili questi canali eliminando qualsiasi timore per possibili **ritorsioni**
- Determinare le **priorità** dei fatti segnalati
- Stabilire In che modo saranno individuate le **risorse** appropriate per le azioni di follow up
- Target dei **tempi di risposta**
- Determinazione dei processi di **monitoraggio** sono posti in essere
- Impiego di **risorse** tecnologiche e di sicurezza sono adeguate
- Identificazione del team incaricato di svolgere le necessarie **indagini**
- Come saranno documentate e **seguite** le segnalazioni ricevute?
- Rendere informato il segnalante delle **conclusioni** raggiunte e dei provvedimenti presi
- Standard di **documentazione**, report di sintesi e **frequenza**.
- **Miglioramento** continuo

Nuove tendenze di *compliance*

- Etica d'impresa e responsabilità sociale
- Rating ESG (Enviromental, Social & Governance)
- Business and Human Rights
- **Es. settore *automotive* Nuova IATF 16949**

5.1.1.1 *Corporate responsibility*

The organization shall define and implement corporate responsibility policies, including at a minimum an anti-bribery policy, an employee code of conduct, and an ethics escalation policy ("whistle-blowing policy").



2015 Cyber Security Report

Un Framework Nazionale per la Cyber Security

A cura di:
Roberto Baldoni
Luca Montanari



February 12, 2014

Cybersecurity Framework

Version 1.0

Function Unique Identifier	Function	Category Unique Identifier	Category
ID	Identify	ID.AM	Asset Management
		ID.BE	Business Environment
		ID.GV	Governance
		ID.RA	Risk Assessment
		ID.RM	Risk Management Strategy
PR	Protect	PR.AC	Access Control
		PR.AT	Awareness and Training
		PR.DS	Data Security
		PR.IP	Information Protection Processes and Procedures
		PR.MA	Maintenance
		PR.PT	Protective Technology
DE	Detect	DE.AE	Anomalies and Events
		DE.CM	Security Continuous Monitoring
		DE.DP	Detection Processes
RS	Respond	RS.RP	Response Planning
		RS.CO	Communications
		RS.AN	Analysis
		RS.MI	Mitigation
		RS.IM	Improvements
RC	Recover	RC.RP	Recovery Planning
		RC.IM	Improvements
		RC.CO	Communications

The Framework is adaptive to provide a flexible and risk-based implementation that can be used with a broad array of cybersecurity risk management processes. Examples of cybersecurity risk management processes include International Organization for Standardization (ISO) [31000:2009](#)³, [ISO/IEC 27005:2011](#)⁴, National Institute of Standards and Technology (NIST) Special Publication (SP) 800-39⁵, and the *Electricity Subsector Cybersecurity Risk Management Process (RMP) guideline*⁶.



UNIVERSITÀ DEGLI STUDI DI MILANO

ALLEGATO A

DOCUMENTI AZIENDALI PER LA GESTIONE E IL CONTROLLO DEL SISTEMA INFORMATIVO

Documento	Approvazione	Aggiornamento	Note
DOCUMENTI DI <i>POLICY</i> E STANDARD AZIENDALI			
Documento di indirizzo strategico	Organo con funzione di supervisione strategica	In dipendenza della periodicità dei piani strategici aziendali (3 – 5 anni)	Contiene (cfr. Sezione II, par. 1): – modello di riferimento architetturale – strategie di <i>sourcing</i> – propensione al rischio informatico
Metodologia di analisi del rischio informatico	Organo con funzione di supervisione strategica	In base alla necessità	
<i>Policy</i> di sicurezza informatica	Organo con funzione di supervisione strategica	In base alla necessità	
Organigramma della funzione ICT	Organo con funzione di supervisione strategica	In base alla necessità	Include il disegno dei processi di gestione dell'ICT (cfr. Sezione II, par. 2)
Standard di <i>data governance</i>	Organo con funzione di gestione	Periodicità definita	

Sicurezza del trattamento

1. Tenendo conto dello stato dell'arte e dei costi di attuazione, nonché della natura, dell'oggetto, del contesto e delle finalità del trattamento, come anche del rischio di varia probabilità e gravità per i diritti e le libertà delle persone fisiche, il titolare del trattamento e il responsabile del trattamento mettono in atto misure tecniche e organizzative adeguate per garantire un livello di sicurezza adeguato al rischio, che comprendono, tra le altre, se del caso:

a) la pseudonimizzazione e la cifratura dei dati personali;

(44) La responsabilità di garantire la sicurezza delle reti e dei sistemi informativi incombe in larga misura agli operatori di servizi essenziali e ai fornitori di servizi digitali. È opportuno promuovere e sviluppare attraverso adeguati obblighi regolamentari e pratiche industriali volontarie una cultura della gestione del rischio, che comprende la valutazione del rischio e l'attuazione di misure di sicurezza commisurate al rischio corso. È altresì fondamentale

Whistleblowing da analogico a digitale

- La tecnologia come fattore abilitante di nuove modalità di whistleblowing
- Riduzione di barriere all'ingresso per i whistleblowing
- Gestione flessibile di categorie e campi di segnalazione
- Livelli di sicurezza configurabili (anonimo o confidenziale)
- Modalità per consentire al whistleblower di comunicare in modo sicuro

Enorme diffusione del fenomeno dopo Wikileaks

- Attivismo
- Media e giornalismo investigativo
- Autorità Nazionali Anticorruzione & Transparency International ALAC
- Organizzazioni pubbliche e private
- Iniziative specifiche (rif. <http://leakdirectory.org>)

Il whistleblowing digitale deve essere sicuro!

- **Tutelare dell'identità dei soggetti segnalanti e riservatezza delle informazioni rilasciate**
- Architetture informatiche progettate fin dall'inizio per sfruttare tecniche di protezione dei dati basate su crittografia allo stato dell'arte e tecnologie di anonimato nelle comunicazioni
- Test di sicurezza, revisione del codice, attività di assurance e audit
- Stringenti politiche di data retention
- Separazione dei ruoli: whistleblower, riceventi, amministratori di sistema
- La gestione del controllo degli accessi, dell'autenticazione informatica e della profilazione degli utenti dovrebbe seguire criteri particolarmente rigidi tali da non permettere l'accesso ai dati in chiaro ai soggetti non autorizzati

Soggetti “riceventi”

- Responsabile anticorruzione
- **OdV (reati informatici 23 l!)**
- Internal Audit
- RSPP
- **Data Protection Officer (data breach?!)**
- Security Manager
- Compliance Officer
- Risk Manager
- Altre funzioni di controllo interne/esterne





- Rapporto tra applicazione di misure di sicurezza digitali e tutela dei diritti umani e dei valori fondamentali delle persone
- *For example, security measures can enhance **privacy** protection, or provide anonymity to **whistleblowers** and human rights activists. They can also enable the illegitimate monitoring of citizens, or prevent access to activists' content. They can affect other rights and values not listed in the Principle. Therefore, **a responsible approach requires that decisions to manage digital security risk be made in light of their consequences on these rights and values***

